

INCIT 2026 · BANGKOK, THAILAND

Deep Reinforcement Learning Vulnerability Scanner for Web Applications

An Extended D3QN agent that learns to find what static and rule-based scanners miss.

Hein Htet Zaw
Karn Yongsiriwit
Rangsit University

Pentesting doesn't scale with how fast web apps ship

1

Manual pentesting is slow

Skilled testers are expensive and scarce; release cycles now measured in days, not quarters.

2

Static / rule-based scanners plateau

They catch signature-shaped bugs but miss logic flaws that only appear across multi-step workflows.

3

IDOR-class bugs are the blind spot

Broken object-level authorization needs context and state -- exactly what stateless scanners lack.

The gap isn't tooling volume -- it's tools that can't reason across multi-step application state.

Prior DRL scanners solve one vulnerability class at a time

X

Single-vulnerability agents

DRL fuzzers tuned for one bug class (e.g. XSS-only or SQLi-only) -- retraining needed per class.

X

Narrow state representations

Many use raw HTTP text or fixed payload lists instead of a structured, transferable state encoding.

X

No systematic ground-truth check

Detections reported without an independent confirmation step, so false positives inflate reported gains.

Extended D3QN targets all three gaps in one agent, evaluated with an independent ground-truth confirmation step.

Extended D3QN: four Rainbow components, one agent

1

Double DQN

Decouples action selection from evaluation to curb Q-value overestimation.

2

Dueling Networks

Splits state-value and advantage streams for more stable policy learning.

3

Prioritized Experience Replay

Replays rare, high-signal transitions (e.g. confirmed vuln hits) more often.

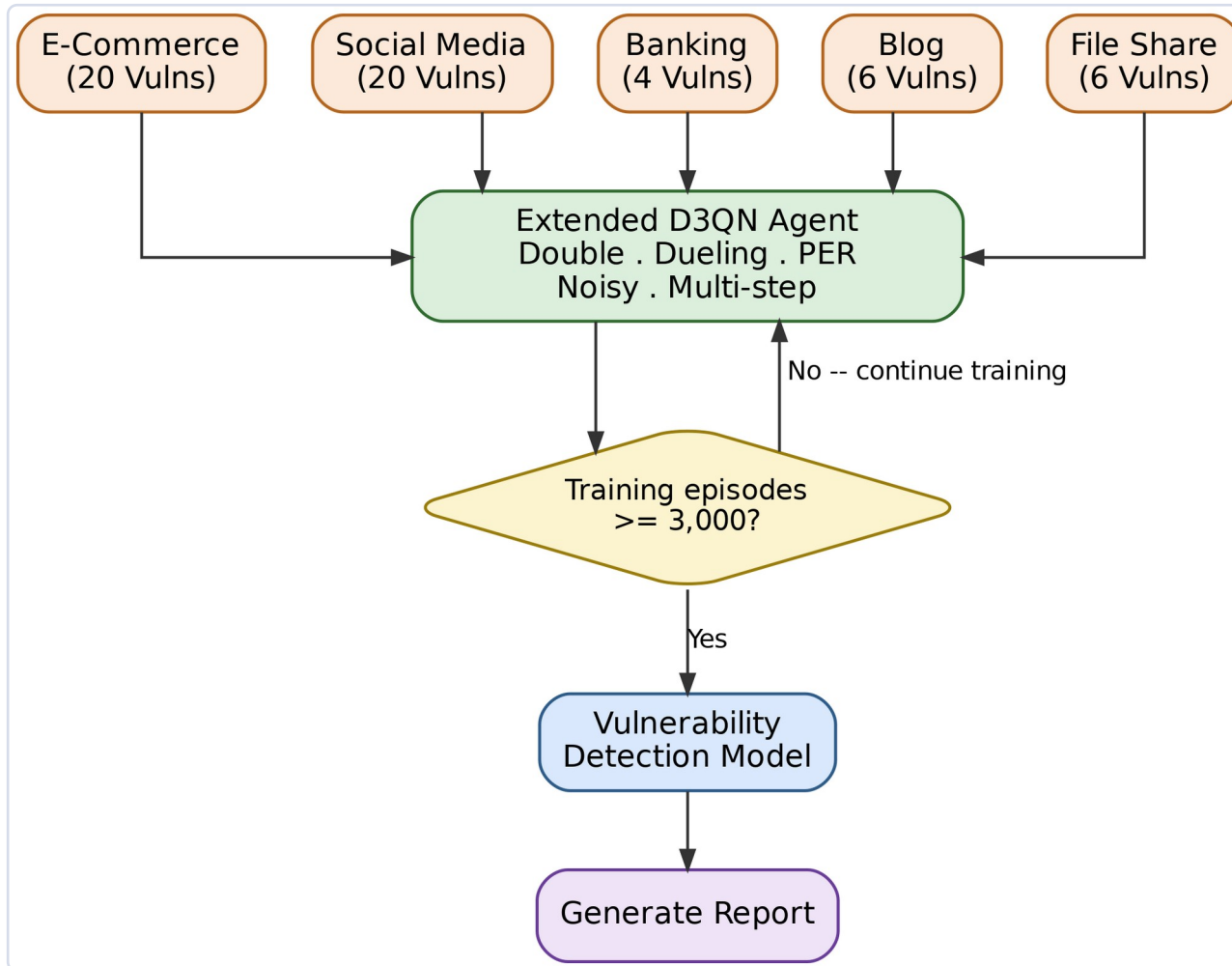
4

Noisy Nets

Learned, parametric exploration -- no manual epsilon-decay schedule to tune.

Plus multi-step returns for longer-horizon credit assignment across multi-request attack chains.

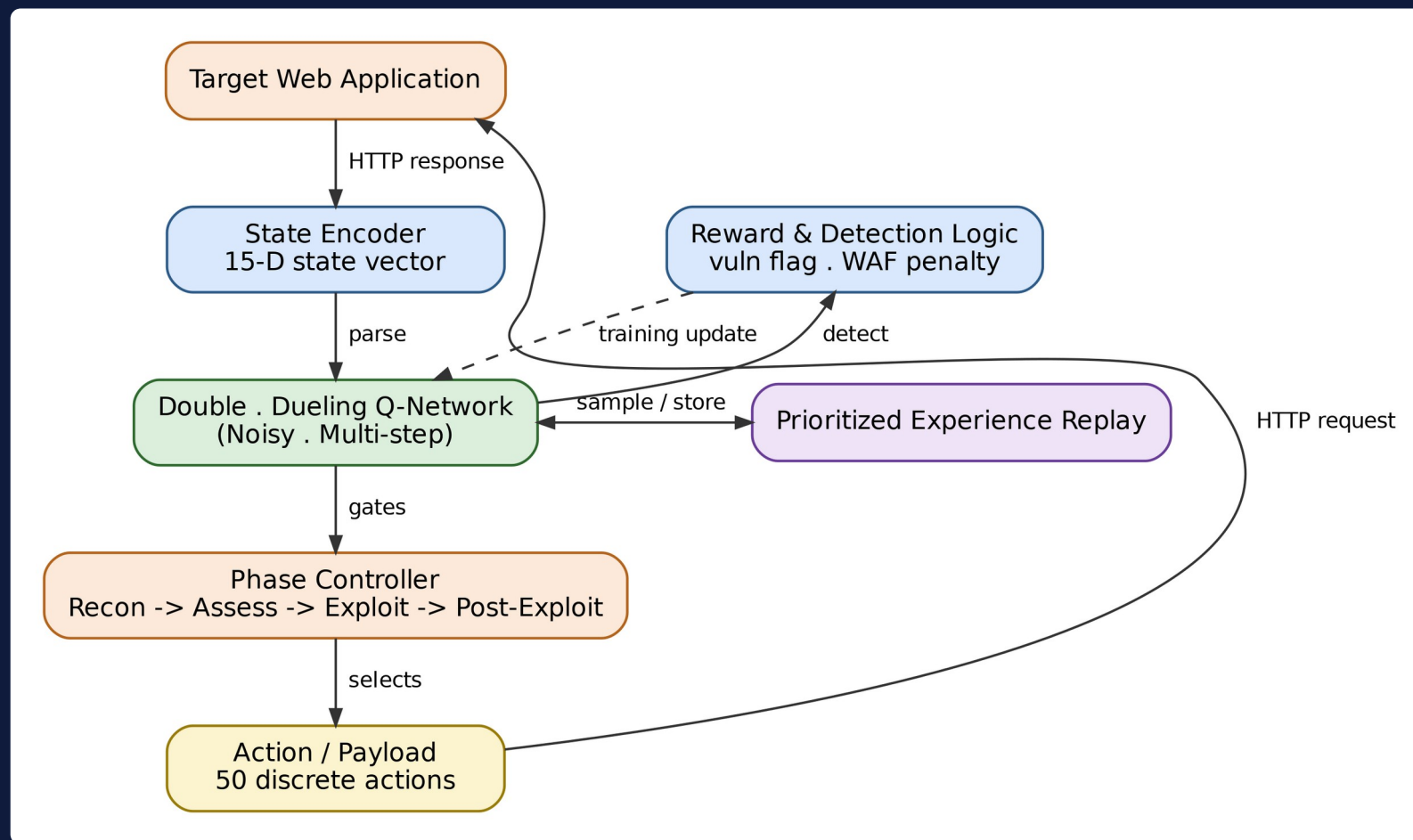
Five mock targets, one agent, one report



How it flows

- 5 mock apps: e-commerce, social media, banking, blog, file share
- 15-D state vector encodes HTTP + DOM signal per step
- Episode budget gate: default 3,000 episodes to convergence
- Confirmed findings only reach the report -- unconfirmed activity is logged separately

From HTTP response to phase-gated action



State encoder -> Double-Dueling Q-Network -> PER -> reward & detection logic -> phase controller -> action

The scan as a Markov Decision Process

15-D

State vector
per HTTP step

50

Discrete
payload actions

4

Curriculum
phases

Reward shaping

Confirmed vulnerability flag

+1.0

WAF / defensive block triggered

-0.1

Wasted / redundant request

-0.01

*Bellman target uses the Double-DQN
correction:*

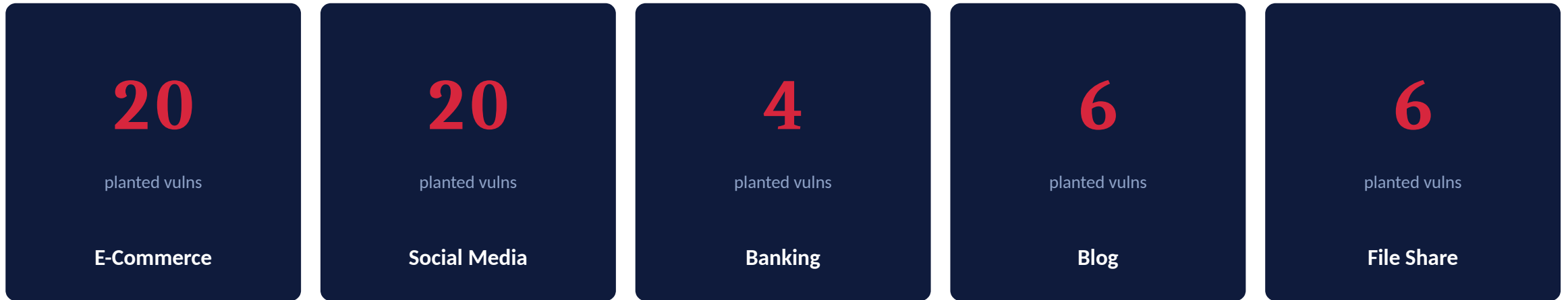
$$\gamma = r + \text{gamma} * Q(s', \text{argmax} \\ Q(s', a'; \theta); \theta')$$

Attacks unlock in phases, like a real engagement



Phase gates are earned, not scripted -- the agent must demonstrate signal before advancing.

Five deliberately vulnerable mock applications

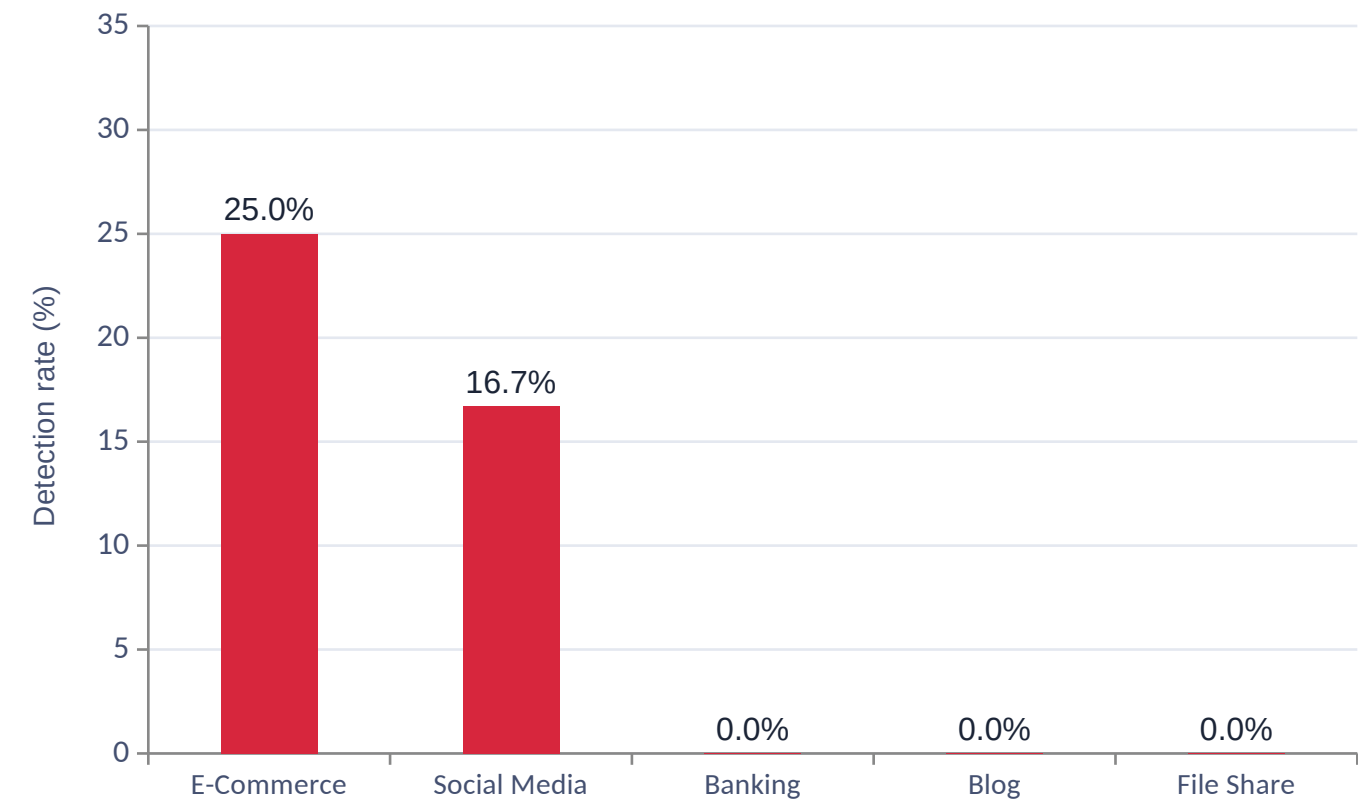


Ground truth for every target is enumerated in code (`run_ground_truth_scan`) -- not estimated -- so detection rate has an exact denominator.

A finding only counts as "confirmed" when both the ground-truth response header and an independent local validator agree.

RESULTS

Confirmed detection rate, per target



IDOR: the one class we confirm

- E-Commerce: 1/4 IDOR findings confirmed (25%)
- Social Media: 1/6 IDOR findings confirmed (16.7%)
- Banking, Blog, File Share: 0 confirmed
- Every other planted class: 0% across all 5 targets

We report this as-is -- the contribution is the honest measurement pipeline, not an inflated win.

More scanning didn't move the needle -- and that's the finding

5x

increase in crawl depth & attack intensity
(depth 150 / intensity 100 vs. 20 / 5)

~3x

more unconfirmed activity flagged

0

change in confirmed detections

Same single IDOR finding reconfirmed on E-Commerce and Social Media;
Banking, Blog, and File Share stayed at zero.

Ground-truth confirmation resists false-positive inflation from more aggressive scanning.

Conclusion: the detection gap is structural, not a symptom of under-scanning.

Limitations, honestly stated -- and what's next

Limitations

- Confirmed detection is narrow -- IDOR only, on 2 of 5 targets
- Single-agent architecture; no multi-agent or transfer study yet
- Reward shaping is hand-tuned, not learned or ablated per-term

Future Work

- Scale past $n=5$ seeds -- current Wilcoxon floor ($p=0.0625$) blocks pairwise significance even on a clean sweep
- Multi-seed, multi-run replication of the live Table I scan (currently single-seed, unlike the 5-seed ablation study)
- Expand curriculum to auth-bypass and SSRF-style multi-step chains

Contribution: a reproducible, ground-truth-verified DRL pipeline for web vulnerability discovery -- built to be extended, not overclaimed.

Thank you

Questions welcome.

Hein Htet Zaw • Karn Yongsiriwit

Rangsit University

InCIT 2026, Bangkok